

Cahier des charges complet — ProofDesk SaaS

Version : 1.0 — document de cadrage produit et technique

Date : 29 septembre 2026

Produit : ProofDesk

Domaine public actuel : Vendeviaa / ProofDesk Audit

Statut : spécification cible avant construction du SaaS complet

Document destiné à : fondateur, produit, développement, sécurité, vente et partenaires

0. Décision de cadrage

ProofDesk ne doit pas devenir une plateforme généraliste de conformité. Le produit doit rester concentré sur un problème commercial précis : **répondre plus vite aux questionnaires de sécurité des grands comptes, sans inventer de réponse et sans perdre la traçabilité des preuves.**

Le parcours produit cible est :

Importer les preuves → importer un questionnaire → proposer des réponses justifiées
→ faire valider par un humain → exporter fidèlement → capitaliser les réponses
approuvées → publier éventuellement un Trust Center.

L'Audit express public est la porte d'entrée commerciale. Il qualifie le problème et prépare le passage au SaaS, mais il ne constitue pas le SaaS lui-même.

Règle absolue

Aucune réponse ne doit être présentée comme fiable si elle ne peut pas être reliée à une source vérifiable, à une date et à une validation humaine. En l'absence de preuve, ProofDesk doit afficher une lacune (gap) plutôt qu'inventer.

1. Résumé exécutif

1.1 Problème

Les PME SaaS B2B qui vendent à des grands comptes reçoivent des questionnaires de sécurité, de confidentialité, de sous-traitance ou de conformité. Ces demandes arrivent sous forme de fichiers Excel, Word, CSV, PDF ou de portails clients.

Elles impliquent souvent le CTO, la sécurité, le juridique, le DPO, l'avant-vente et la direction. Les difficultés principales sont :

- réponses dispersées dans Excel, Word, Drive, Notion ou SharePoint ;
- documents expirés ou sans propriétaire ;
- réponses contradictoires entre deux questionnaires ;
- absence de bibliothèque approuvée ;
- difficulté à retrouver la preuve exacte ;
- validations qui se font par e-mail sans historique ;
- export qui dégrade ou modifie le fichier original ;
- ventes retardées faute de réponse suffisamment documentée ;
- peur de répondre trop vite et de créer un risque contractuel.

1.2 Solution

ProofDesk est un **copilote de réponses sécurité orienté vente**. Il aide une organisation à transformer un questionnaire entrant en un brouillon :

- structuré ;
- justifié par des citations issues des documents de l'organisation ;
- accompagné d'un niveau de confiance explicable ;
- signalant les preuves manquantes, expirées ou contradictoires ;
- soumis à une validation humaine obligatoire ;
- exportable dans le format d'origine.

1.3 Valeur client

Le client doit pouvoir :

1. traiter un premier questionnaire le jour de l'onboarding ;
2. réduire le temps de recherche des preuves ;
3. répondre de façon cohérente entre les demandes ;
4. voir immédiatement les lacunes qui peuvent bloquer une vente ;
5. prouver qui a validé quelle réponse et à quelle date ;
6. capitaliser les réponses approuvées pour les prochains questionnaires ;
7. partager une présentation professionnelle de sa posture via un Trust Center.

1.4 Promesse autorisée

ProofDesk prépare des réponses documentées et réutilisables. Votre équipe garde la validation finale.

1.5 Promesses interdites

ProofDesk ne doit jamais affirmer :

- qu'il rend automatiquement une entreprise conforme au RGPD, à NIS2, à DORA, à ISO 27001 ou à SOC 2 ;
- qu'une réponse est exacte sans citation vérifiée ;
- qu'un gain de temps est garanti ;
- qu'un score d'Audit est une note de sécurité ou une certification ;
- que les données sont hébergées en Europe si cette affirmation n'est pas contractuellement et techniquement vérifiée ;
- que l'IA remplace le RSSI, le DPO, le juriste ou la direction.

2. Positionnement et marché initial

2.1 Cible prioritaire — ICP

Entreprise SaaS B2B française ou européenne :

- 30 à 150 salariés ;
- vendant à des entreprises de 250 à 500+ salariés ;
- recevant au moins 3 à 5 questionnaires ou revues sécurité par trimestre ;
- utilisant encore plusieurs sources documentaires ;
- n'ayant pas de bibliothèque fiable de réponses approuvées ;
- ayant déjà retardé une vente pour une raison de sécurité ou de confidentialité ;
- disposant d'un CTO, d'un responsable sécurité ou d'un DPO à temps partiel ou partagé.

2.2 Utilisateurs

Persona	Besoin principal	Utilisation
Fondateur / CEO	Ne pas perdre une vente stratégique	Suivi du ROI, validation des réponses sensibles
CTO / VP Engineering	Réduire les interruptions	Validation technique, preuves d'architecture et de sauvegarde
RSSI / Responsable sécurité	Maintenir la cohérence	Bibliothèque, propriétaires, expiration, revue
DPO / Juriste	Contrôler les affirmations	Réponses RGPD, sous-traitants, transferts, contrats
Sales Engineer / Avant-vente	Répondre rapidement	Création de questionnaire, revue, export
Contributeur	Traiter les questions assignées	Propositions, commentaires, sources
Approbateur	Valider le contenu	Approbation, rejet, demande de correction
Prospect final	Évaluer le fournisseur	Consultation du Trust Center ou du questionnaire final

2.3 Hors cible de la V1

- grands groupes avec une équipe GRC complète ;

- gestion complète des audits ISO 27001 ou SOC 2 ;
- plateforme de gestion de risques fournisseurs généraliste ;
- marketplace d'auditeurs ;
- conformité réglementaire automatisée ;
- réponse automatique sans validation ;
- support de tous les portails propriétaires dès la V1.

2.4 Différenciation

La différenciation repose sur une combinaison :

1. spécialisation PME SaaS B2B ;
 2. contexte français et européen ;
 3. réponses reliées à des preuves et à des extraits littéraux ;
 4. validation humaine obligatoire ;
 5. détection des lacunes orientée vente ;
 6. export fidèle au fichier du client ;
 7. Trust Center bilingue orienté décision ;
 8. accompagnement humain en français ;
 9. mesure du temps, du délai et des ventes potentiellement débloquées.
-

3. Objectifs et indicateurs de succès

3.1 Objectifs produit

- permettre un onboarding compréhensible en moins de 15 minutes ;
- traiter un premier questionnaire réel le jour même ;
- afficher une preuve ou une lacune pour chaque réponse proposée ;
- permettre une revue rapide clavier-first ;
- produire un export ouvrable dans le logiciel d'origine ;

- rendre toutes les actions sensibles traçables ;
- éviter toute fuite entre organisations ;
- rendre les résultats compréhensibles par un profil technique et un profil commercial.

3.2 Indicateurs SaaS

Indicateur	Définition	Cible initiale à valider
Time to first value	Temps entre création du compte et premier questionnaire importé	Moins d'une journée
Time to first export	Temps entre import et premier export validé	Moins d'une journée
Taux de couverture	Questions ayant une preuve exploitable	À suivre par questionnaire
Taux de gap	Questions sans preuve suffisante	Doit diminuer avec la bibliothèque
Taux d'approbation directe	Réponses approuvées sans modification	Signal de qualité, pas objectif isolé
Taux de modification	Réponses modifiées par un humain	Signal de correction du système
Taux de rejet	Réponses rejetées	Signal de qualité ou de données manquantes
Délai moyen de réponse	Création du questionnaire → export	À comparer avant/après
Temps gagné déclaré	Estimation du client	Ne pas présenter comme garanti
Questionnaires mensuels	Usage récurrent	Mesure de rétention
Trust Center publié	Organisation ayant publié une version	Signal d'adoption avancée
Rétention	Organisations actives à 30/90 jours	À définir après pilotes

3.3 Indicateurs commerciaux

- nombre d'Audits complétés ;

- taux Audit → rendez-vous ;
 - taux Audit → création de compte ;
 - taux compte → premier document ;
 - taux compte → premier questionnaire ;
 - taux compte → premier export ;
 - nombre de pilotes payants ;
 - revenu mensuel récurrent ;
 - coût d'acquisition par canal ;
 - délai moyen entre Audit et pilote ;
 - conversion par post ou campagne Instagram.
-

4. Périmètre global du produit

4.1 Modules du produit

Module A — Site public et Audit express

Déjà commencé dans ProofDesk Audit :

- landing page ;
- formulaire Audit progressif ;
- calcul déterministe ;
- rapport immédiat ;
- export PDF serveur ;
- téléchargement des données ;
- consentement ;
- UTM et événements de parcours.

À compléter :

- version bilingue FR/EN ;
- anti-spam et rate limiting ;

- statut lead visible au fondateur ;
- transition Audit → onboarding prérempli ;
- génération de lien de reprise sécurisé ;
- page de prise de rendez-vous ;
- politique de conservation et suppression réellement opérées.

Module B — Authentification et organisations

- connexion sécurisée ;
- création d'une organisation ;
- invitation d'utilisateurs ;
- rôles et permissions ;
- changement d'organisation éventuel ;
- paramètres de langue ;
- profil et préférences ;
- suppression ou export de l'organisation.

Module C — Bibliothèque documentaire

- import de documents ;
- extraction de texte ;
- versions ;
- métadonnées ;
- propriétaire ;
- dates d'émission et d'expiration ;
- statut de validation ;
- recherche ;
- prévisualisation ;
- téléchargement sécurisé ;
- rappels d'expiration.

Module D — Questionnaires

- import Excel, Word et CSV en V1 ;

- mapping assisté ;
- détection des questions ;
- catégories ;
- assignation ;
- échéance ;
- statut global ;
- vue de progression ;
- historique ;
- import PDF en V2 ;
- intégration portails en V2 ou ultérieurement.

Module E — Réponses et revue

- réponse proposée ;
- citation et extrait ;
- confiance explicable ;
- statut ;
- commentaires ;
- assignation ;
- approbation ;
- rejet ;
- demande de correction ;
- détection des contradictions ;
- détection des preuves expirées ;
- export uniquement après validation par défaut.

Module F — Bibliothèque de réponses approuvées

- recherche par question ;
- recherche par mots-clés ;
- langue ;
- domaine ;

- date d'approbation ;
- approbateur ;
- période de validité ;
- preuves liées ;
- versioning ;
- réutilisation dans les questionnaires futurs.

Module G — Gap Report

- lacunes par domaine ;
- priorité commerciale ;
- preuve attendue ;
- propriétaire suggéré ;
- effort estimé ;
- action recommandée ;
- export PDF ;
- suivi jusqu'à résolution.

Module H — Tableau de bord

- questionnaires en cours ;
- délai moyen ;
- questions à valider ;
- preuves expirant bientôt ;
- taux de couverture ;
- lacunes critiques ;
- temps déclaré ou estimé ;
- exports récents ;
- ventes ou opportunités associées, si renseignées.

Module I — Trust Center

- page publique bilingue ;
- informations générales ;

- documents validés ;
- réponses approuvées ;
- contact sécurité ;
- date de mise à jour ;
- domaine personnalisé ;
- documents publics, protégés ou privés ;
- demande d'accès contrôlée ;
- historique des publications.

Module J — Administration et sécurité

- membres ;
- rôles ;
- journal d'audit ;
- export des données ;
- suppression ;
- paramètres de rétention ;
- sous-traitants ;
- informations de sécurité du produit ;
- sauvegardes et restauration ;
- incidents.

Module K — Pilotage fondateur

- leads Audit ;
- origine et UTM ;
- statut du lead ;
- Audit complété ou abandonné ;
- PDF généré ou téléchargé ;
- compte créé ;
- premier document ;
- premier questionnaire ;

- premier export ;
 - suivi des pilotes.
-

5. Parcours utilisateurs détaillés

5.1 Parcours visiteur → Audit

1. Le visiteur arrive sur la landing.
2. Il comprend le problème en moins de 30 secondes.
3. Il lance l'Audit sans créer de compte.
4. Il répond à quatre étapes progressives.
5. Le brouillon est enregistré localement pendant le parcours.
6. Les réponses sont validées côté navigateur et côté serveur.
7. Le prospect accepte le consentement avant soumission.
8. Le moteur calcule un diagnostic explicable.
9. Le rapport est visible immédiatement.
10. Le prospect peut télécharger le PDF et les données.
11. Le prospect choisit une prochaine étape : rendez-vous, démonstration, pilote, rapport uniquement ou rappel ultérieur.
12. Avec consentement, le lead est enregistré et son origine est conservée.

5.2 Parcours Audit → SaaS

Après le rapport, le bouton principal doit proposer :

Créer mon espace ProofDesk à partir de cet audit

Données préremplies possibles, uniquement après consentement :

- prénom ;
- nom ;
- e-mail ;

- rôle ;
- entreprise ;
- contexte commercial ;
- niveau de charge ;
- priorités identifiées ;
- langue choisie.

Le prospect doit pouvoir corriger ou refuser chaque information préremplie.

5.3 Onboarding organisation

Checklist obligatoire :

1. nom de l'organisation ;
2. langue par défaut ;
3. fuseau horaire ;
4. invitation des premiers utilisateurs ;
5. import d'au moins un document ;
6. définition des propriétaires de preuves ;
7. import d'un questionnaire exemple ou réel ;
8. confirmation du mapping ;
9. première revue ;
10. premier export.

Un exemple non sensible doit être disponible pour permettre une démonstration sans importer immédiatement des documents confidentiels.

5.4 Parcours questionnaire

1. L'utilisateur clique sur **Nouveau questionnaire**.
2. Il importe un fichier.
3. Le système contrôle le type, la taille et la sécurité du fichier.
4. Le système détecte les feuilles, tableaux, colonnes et zones de réponse.
5. Il propose un mapping.

6. L'utilisateur confirme ou corrige le mapping.
7. Le système crée les questions sans modifier le fichier original.
8. Le traitement asynchrone démarre.
9. La progression est visible, par exemple 47/180 questions analysées .
10. Chaque question reçoit une proposition, une citation ou un gap .
11. L'utilisateur filtre les questions à risque.
12. Il assigne les questions nécessaires.
13. Les approbateurs valident, modifient ou rejettent.
14. Le système contrôle les erreurs avant export.
15. L'utilisateur génère l'export final.
16. Le système journalise l'export, l'utilisateur, la date, la version du questionnaire et la version des réponses.

5.5 Parcours de revue d'une question

La vue doit présenter :

Colonne principale

- texte original de la question ;
- cellule ou emplacement d'origine ;
- type de réponse attendu ;
- réponse proposée ;
- statut ;
- confiance ;
- commentaire ;
- actions : approuver, modifier, rejeter, assigner.

Panneau preuve

- document source ;
- version ;
- page ou section ;
- extrait littéral surligné ;

- date de validité ;
- propriétaire ;
- lien vers le document ;
- autres sources contradictoires éventuelles.

Règle de validation

Une réponse ne peut être **approved** que si :

- elle possède au moins une citation vérifiée, sauf réponse explicitement déclarée non applicable avec justification ;
- les preuves utilisées ne sont pas expirées, ou l'exception est confirmée par un approbateur ;
- l'approbateur dispose du rôle requis ;
- l'action est enregistrée dans le journal d'audit.

5.6 Parcours Gap Report

Le Gap Report doit regrouper les lacunes par :

- impact commercial ;
- domaine ;
- urgence ;
- propriétaire ;
- effort ;
- échéance.

Exemple :

Lacune : aucun élément vérifiable sur les tests de restauration des sauvegardes.

Risque commercial : question fréquente dans les revues de grands comptes.

Preuve attendue : compte rendu ou rapport de test récent.

Propriétaire suggéré : CTO / responsable infrastructure.

Effort estimé : moyen.

5.7 Parcours Trust Center

1. L'administrateur active le Trust Center.

2. Il choisit les éléments publiables.
 3. Seuls les documents et réponses approuvés apparaissent dans la sélection.
 4. Le système montre une prévisualisation publique.
 5. L'administrateur publie une version.
 6. La date et l'auteur de publication sont conservés.
 7. Les changements suivants créent une nouvelle version.
 8. Les prospects peuvent consulter la page publique.
 9. Les documents contrôlés nécessitent une demande d'accès et, selon la décision future, une validation ou un NDA.
-

6. Fonctionnalités détaillées

6.1 Authentification

V1

- connexion via fournisseur éprouvé ;
- session sécurisée ;
- déconnexion ;
- expiration et renouvellement de session ;
- récupération contrôlée ;
- invitation par e-mail lorsque le fournisseur sera activé ;
- contrôle d'accès côté serveur, jamais seulement dans l'interface.

V1.5 / V2

- MFA obligatoire pour Admin et Approbateur ;
- SSO SAML/OIDC ;
- SCIM ;
- domaines d'e-mail autorisés ;
- gestion avancée des sessions.

6.2 Organisations et rôles

Rôle	Voir	Modifier	Approuver	Exporter	Gérer membres	Publier Trust Center
Owner	Oui	Oui	Oui	Oui	Oui	Oui
Admin	Oui	Oui	Oui	Oui	Oui	Oui
Contributeur	Oui	Oui	Non par défaut	Non par défaut	Non	Non
Approbateur	Oui	Commentaires	Oui	Selon règle	Non	Non
Lecteur	Oui	Non	Non	Non par défaut	Non	Non

Les permissions doivent être contrôlées sur chaque requête et chaque objet. Une URL directe ne doit jamais permettre l'accès à une organisation différente.

6.3 Documents et preuves

Métadonnées minimales

- titre ;
- catégorie ;
- type ;
- langue ;
- propriétaire ;
- date d'émission ;
- date d'expiration ;
- statut ;
- organisation ;
- version ;
- empreinte de fichier ;

- utilisateur ayant importé ;
- date d'import ;
- source ou contexte ;
- niveau de confidentialité.

Catégories initiales

- politique de sécurité ;
- gestion des accès ;
- sauvegarde et restauration ;
- continuité et reprise ;
- gestion des incidents ;
- sous-traitants ;
- RGPD et DPA ;
- chiffrement ;
- vulnérabilités et pentests ;
- hébergement ;
- certifications ;
- formation ;
- réponses précédemment approuvées ;
- autre.

États

- brouillon ;
- en cours de validation ;
- valide ;
- bientôt expiré ;
- expiré ;
- archivé ;
- remplacé par une nouvelle version.

6.4 Import documentaire

Formats V1 :

- PDF natif ;
- DOCX ;
- XLSX ;
- TXT ;
- Markdown.

Contraintes :

- taille maximale configurable ;
- extension et type MIME contrôlés ;
- antivirus ou sandbox d'analyse ;
- aucun fichier exécuté ;
- protection contre les archives malicieuses ;
- détection de doublons ;
- conservation de l'original ;
- extraction asynchrone ;
- journalisation de l'échec ;
- retrait possible par l'administrateur.

Les scans nécessitent un pipeline OCR séparé. Le résultat OCR doit être marqué comme tel et ne doit pas être traité comme une transcription parfaite sans vérification.

6.5 Base de connaissance

Chaque fragment indexé doit conserver :

- organisation ;
- document ;
- version ;
- page ou section ;
- texte original ;

- langue ;
- date d'extraction ;
- statut du document ;
- propriétaire ;
- empreinte ;
- représentation de recherche ;
- informations de sécurité nécessaires à l'isolation.

La recherche doit combiner :

1. recherche lexicale ;
2. recherche sémantique ;
3. reranking ;
4. priorité aux réponses approuvées ;
5. filtrage par organisation, langue, statut et validité.

6.6 Import et mapping questionnaire

Formats V1

- XLSX ;
- DOCX ;
- CSV.

Cas Excel à gérer

- plusieurs feuilles ;
- cellules fusionnées ;
- colonnes cachées ;
- lignes masquées ;
- validations de données ;
- listes Oui / Non / N.A. ;
- formules ;
- formats conditionnels ;

- macros `.xlsm` : support explicitement refusé ou préservé avec avertissement ;
- questions hiérarchiques ;
- sous-questions conditionnelles ;
- langues multiples.

Cas Word à gérer

- tableaux ;
- tableaux imbriqués ;
- contrôles de contenu ;
- cases à cocher ;
- styles ;
- en-têtes et pieds de page ;
- questions en paragraphes.

Cas CSV à gérer

- UTF-8 ;
- Windows-1252 ;
- séparateurs virgule, point-virgule ou tabulation ;
- guillemets ;
- retours à la ligne dans une cellule ;
- encodage détecté et affiché.

6.7 Génération de réponses

Pour chaque question :

- question originale ;
- intention détectée ;
- type attendu ;
- réponse proposée ;
- citations ;
- confiance ;

- signaux de confiance ;
- lacune ;
- preuve expirée ;
- contradiction ;
- langue ;
- version du modèle ;
- version du prompt ;
- date de génération ;
- statut de revue.

La génération doit être structurée en sortie contrôlée. Le système ne doit pas produire une réponse libre impossible à auditer.

6.8 États des réponses

```
draft_ai  
needs_review  
approved  
edited  
rejected  
gap  
expired_evidence  
conflict  
not_applicable_pending  
not_applicable_approved
```

Seules les réponses approuvées sont exportables par défaut.

Tout forçage d'export d'une réponse non approuvée doit :

- afficher un avertissement explicite ;
- demander une confirmation ;
- exiger un rôle autorisé ;
- écrire une entrée immuable dans le journal.

6.9 Bibliothèque de réponses approuvées

Une réponse approuvée doit être réutilisable mais jamais copiée aveuglément. Avant réutilisation, le système vérifie :

- langue ;
- contexte ;
- date de validation ;
- validité des preuves ;
- organisation et produit concernés ;
- différences avec la question actuelle ;
- éventuelles contradictions.

Une réponse peut être marquée **à revoir** lorsqu'une preuve liée expire.

6.10 Export fidèle

L'export est un risque majeur du produit.

Le système doit :

- modifier uniquement les cellules ou zones de réponse ;
- préserver la structure ;
- préserver les feuilles ;
- préserver les styles ;
- préserver les validations ;
- préserver les formules ;
- préserver les filtres ;
- préserver les largeurs et hauteurs ;
- préserver les commentaires existants ;
- ne pas écraser l'original ;
- conserver une copie de l'export ;
- produire un rapport de comparaison structurelle ;
- signaler clairement les limites d'un format non supporté.

Si l'export fidèle est impossible, ProofDesk doit refuser silencieusement le résultat. Il doit afficher une erreur explicite et proposer un export de secours séparé.

6.11 Commentaires et assignations

Chaque question peut recevoir :

- un commentaire ;
- une assignation ;
- une échéance ;
- une mention d'équipe ;
- une demande de justification ;
- une demande de document ;
- un historique des changements.

6.12 Rappels

Rappels futurs :

- preuve expirant dans 90 jours ;
- preuve expirant dans 30 jours ;
- question assignée en retard ;
- questionnaire proche de son échéance ;
- réponse approuvée liée à une preuve devenue invalide ;
- Trust Center à republier après changement important.

Le canal initial peut être une notification interne. L'e-mail transactionnel sera ajouté lorsque Resend sera réellement configuré.

7. Moteur IA et fiabilité

7.1 Architecture recommandée

Pipeline :

1. upload sécurisé ;
2. extraction ;
3. normalisation ;
4. versioning ;
5. découpage sémantique ;
6. indexation lexicale et vectorielle ;
7. analyse de la question ;
8. recherche de preuves ;
9. génération structurée ;
10. vérification des citations ;
11. contrôles métier ;
12. calcul de confiance ;
13. création d'une tâche de revue ;
14. approbation humaine ;
15. export.

7.2 Citation obligatoire

Une citation doit être :

- littérale ;
- retrouvable dans le document source ;
- liée à un document et une version ;
- localisable par page, section ou cellule ;
- contrôlée automatiquement par correspondance ;
- visible par le réviseur.

7.3 Gestion de l'incertitude

Le système doit privilégier :

- `gap` si aucune preuve ;
- `conflict` si les sources se contredisent ;
- `expired_evidence` si la preuve est ancienne ou expirée ;
- `needs_review` si la couverture est partielle ;
- réponse courte et prudente plutôt qu'une affirmation absolue.

7.4 Protection contre les injections

Les documents et questionnaires sont des **données non fiables**. Une instruction présente dans un fichier ne doit jamais modifier les règles système.

Tests obligatoires :

- document contenant « ignore previous instructions » ;
- question demandant de révéler le prompt ;
- document essayant de produire une fausse preuve ;
- contradiction entre deux versions ;
- document avec données appartenant à une autre organisation ;
- question hors périmètre.

7.5 Non-entraînement

Les données clients ne doivent pas être utilisées pour entraîner un modèle. Cette règle doit être couverte par :

- contrat avec le fournisseur ;
- configuration de rétention ;
- DPA ;
- documentation client ;
- tests et contrôles internes.

7.6 Évaluation avant production

Créer un jeu d'évaluation composé de :

- documents fictifs réalistes ;
- questionnaires publics ;
- questionnaires anonymisés de prospects ;
- versions françaises et anglaises ;
- cas de preuves expirées ;
- contradictions ;
- questions ambiguës ;
- questions sans réponse ;
- injections de prompt.

Mesures :

- précision factuelle ;
- fidélité aux citations ;
- taux d'hallucination ;
- taux d'abstention pertinente ;
- calibration de la confiance ;
- rappel de la recherche ;
- temps de traitement ;
- coût IA par questionnaire.

Aucun changement de modèle ou de prompt ne doit passer en production sans régression sur ce jeu.

8. Architecture technique cible

8.1 Principes

- architecture multi-tenant ;

- séparation stricte des données par organisation ;
- traitement asynchrone pour les fichiers et l'IA ;
- stockage objet sécurisé ;
- liens signés et expirants ;
- migrations versionnées ;
- logs structurés sans contenu sensible ;
- observabilité ;
- environnements dev, staging et production ;
- possibilité de changer de fournisseur IA.

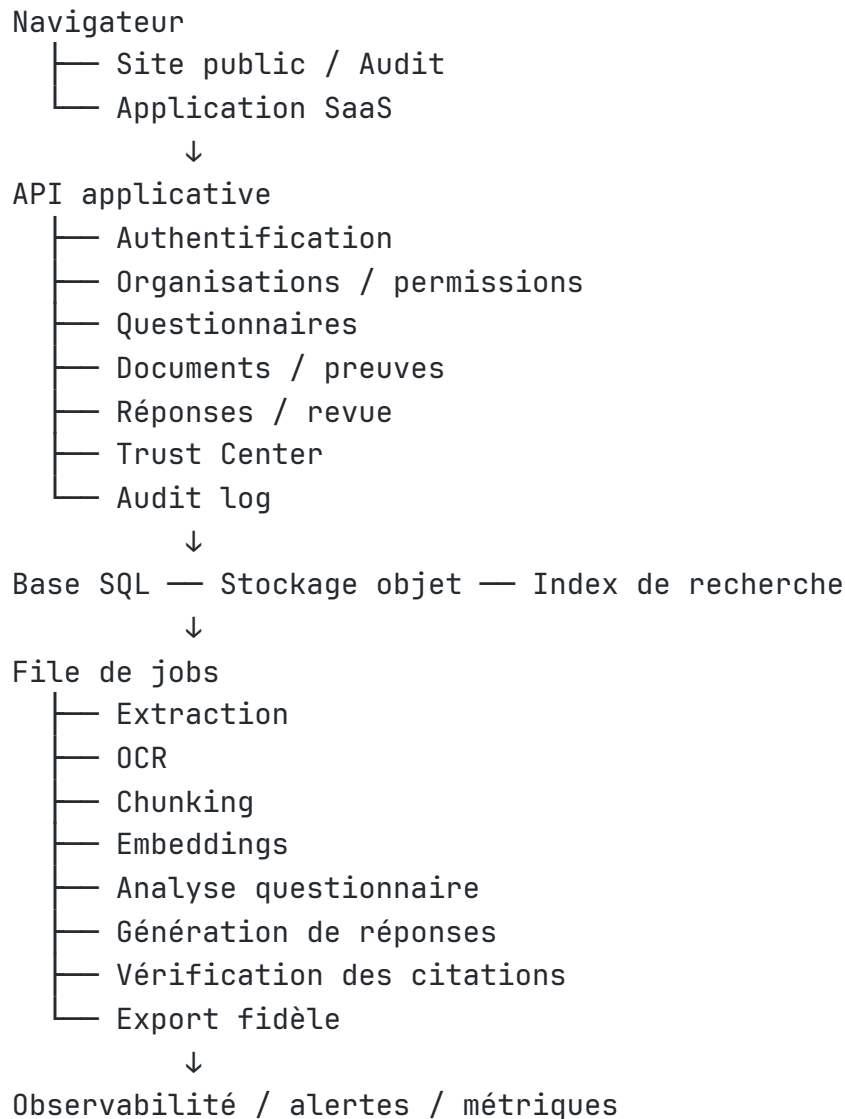
8.2 Stack de référence

La stack actuelle ProofDesk peut servir de base pour l'Audit et le premier socle SaaS :

- React + TypeScript ;
- serveur TypeScript ;
- tRPC pour les contrats internes ;
- base SQL ;
- stockage objet compatible S3 ;
- génération PDF serveur ;
- Vercel pour le frontend et les fonctions compatibles ;
- service de jobs séparé dès que le traitement documentaire devient lourd.

Pour le SaaS documentaire complet, l'architecture devra évoluer vers une solution capable de traiter correctement les fichiers Office et les jobs asynchrones. Le choix définitif du fournisseur cloud, de la région UE, du moteur vectoriel et du fournisseur IA doit être confirmé avant la production commerciale large.

8.3 Composants



8.4 Traitement asynchrone

Chaque job doit être :

- idempotent ;
- relançable ;
- observable ;
- associé à une organisation ;
- associé à une version de document ou questionnaire ;

- protégé contre la double exécution ;
- capable d'échouer avec un message utile.

8.5 Stockage fichiers

- stockage objet en région choisie et documentée ;
 - préfixe par organisation ;
 - chiffrement au repos ;
 - URL signée expirante ;
 - accès contrôlé par le serveur ;
 - antivirus ;
 - quotas ;
 - suppression complète ;
 - conservation de l'empreinte ;
 - versioning si disponible.
-

9. Modèle de données cible

Le modèle actuel contient déjà `users` , `organizations` , `organizationMembers` , `questionnaires` , `evidence` , `auditLeads` et `auditEvents` . Il doit évoluer vers le modèle suivant.

9.1 Tables principales

Organization

- id
- name
- slug
- plan
- locale
- timezone
- data_region
- created_at
- updated_at

User

- id
- email
- name
- status
- mfa_enabled
- created_at
- last_signed_in

OrganizationMember

- id
- organization_id
- user_id
- role
- status
- invited_at
- joined_at

Lead

- id
- source
- utm_source
- utm_medium
- utm_campaign
- email
- company
- consent_at
- consent_version
- status
- created_at

Audit

- id
- lead_id
- answers_json
- scores_json
- findings_json
- language
- pdf_reference
- created_at

Document

- id
- organization_id
- title
- type
- owner_id
- issued_at
- expires_at
- status
- language
- current_version_id

DocumentVersion

- id
- document_id
- storage_key
- checksum
- uploaded_by
- uploaded_at
- extraction_status

Chunk

- id
- document_version_id
- page
- section
- cell_reference
- text
- embedding_reference
- metadata_json

CompanyFact

- id

- organization_id
- key
- value
- source_chunk_id
- validated_by
- validated_at
- status

Questionnaire

- id
- organization_id
- customer_name
- storage_key
- format
- mapping_json
- status
- due_at
- created_by
- created_at

Question

- id
- questionnaire_id
- position
- sheet_name
- cell_reference
- raw_text
- normalized_text
- expected_type
- category
- assigned_to
- due_at

Answer

- id
- question_id
- text
- value
- status
- confidence
- confidence_signals_json
- model_version
- prompt_version
- created_at

- updated_at

Citation

- id
- answer_id
- chunk_id
- quote
- location
- verified

Review

- id
- answer_id
- reviewer_id
- action
- comment
- created_at

ApprovedAnswer

- id
- organization_id
- canonical_question
- answer_text
- evidence_refs
- language
- approved_by
- approved_at
- valid_until

Export

- id
- questionnaire_id
- created_by
- storage_key
- format
- structural_diff_status
- created_at

TrustCenter

- id
- organization_id
- slug
- custom_domain
- status

- default_language
- published_at

TrustItem

- id
- trust_center_id
- document_id / approved_answer_id
- visibility
- sort_order

Reminder

- id
- organization_id
- target_type
- target_id
- due_at
- status

AuditLog

- id
- organization_id
- actor_id
- action
- target_type
- target_id
- metadata_json
- created_at

Event

- id
- organization_id nullable
- session_id
- event_name
- properties_json
- created_at

9.2 Règles de données

- tous les horodatages internes sont en UTC ;
- affichage converti dans le fuseau de l'utilisateur ;
- aucune donnée de fichier dans une colonne SQL ;

- aucune clé secrète en base non chiffrée ;
 - suppression et export organisationnels complets ;
 - conservation des versions nécessaires à la traçabilité ;
 - journal d'audit immuable ;
 - index et cache toujours filtrés par organisation.
-

10. API et intégrations

10.1 API interne

L'API interne doit couvrir :

- `auth.me` ;
 - `organizations.current` ;
 - `organizations.members.list` ;
 - `organizations.members.invite` ;
 - `documents.list` ;
 - `documents.createUpload` ;
 - `documents.completeUpload` ;
 - `documents.updateMetadata` ;
 - `documents.archive` ;
 - `questionnaires.create` ;
 - `questionnaires.import` ;
 - `questionnaires.mapping.preview` ;
 - `questionnaires.mapping.confirm` ;
 - `questionnaires.progress` ;
 - `questions.list` ;
 - `answers.generate` ;
 - `answers.approve` ;
 - `answers.reject` ;
-

- `answers.comment` ;
- `answers.assign` ;
- `exports.create` ;
- `exports.status` ;
- `gapReports.create` ;
- `trustCenter.preview` ;
- `trustCenter.publish` ;
- `auditLog.list` ;
- `analytics.events` .

10.2 Webhooks futurs

Webhooks possibles :

- `audit.completed` ;
- `pdf.generated` ;
- `account.created` ;
- `first.questionnaire.imported` ;
- `first.export.created` ;
- `trust_center.published` ;
- `lead.status.changed` .

Les webhooks doivent être :

- signés ;
- rejouables ;
- idempotents ;
- sans données confidentielles inutiles ;
- documentés ;
- révocables.

10.3 Intégrations à ne pas construire avant validation

- Google Drive ;

- SharePoint ;
- Notion ;
- Slack ;
- HubSpot ;
- Salesforce ;
- portails fournisseurs ;
- SSO ;
- CRM complet.

Elles ne doivent être engagées qu'après validation de l'usage central.

11. Sécurité, confidentialité et RGPD

11.1 Exigences techniques

- TLS moderne ;
- chiffrement au repos ;
- secrets hors du code ;
- rotation des secrets ;
- moindre privilège ;
- isolation multi-tenant ;
- contrôles côté serveur ;
- MFA pour les rôles sensibles ;
- protection contre les attaques de session ;
- rate limiting ;
- en-têtes de sécurité ;
- protection SSRF ;
- validation des uploads ;
- sandbox d'analyse ;
- antivirus ;

- logs sans contenu sensible ;
- alertes sur accès anormaux ;
- sauvegardes chiffrées ;
- restauration testée.

11.2 Journal d’audit obligatoire

Événements minimum :

- connexion ;
- déconnexion ;
- invitation ;
- changement de rôle ;
- import de document ;
- suppression ou archivage ;
- changement de métadonnées ;
- génération de réponse ;
- approbation ;
- rejet ;
- export ;
- téléchargement ;
- publication Trust Center ;
- modification des paramètres ;
- export de données ;
- demande de suppression.

11.3 RGPD

À formaliser avec un conseil juridique :

- responsable de traitement et sous-traitant ;
- base légale ;
- finalités ;

- durée de conservation ;
- droit d'accès ;
- droit de rectification ;
- droit d'effacement ;
- droit à la portabilité ;
- gestion des demandes ;
- registre des traitements ;
- DPA ;
- sous-traitants ;
- transferts internationaux ;
- procédure de violation de données.

Le produit ne doit pas collecter de données sensibles inutiles dans l'Audit. Le formulaire doit permettre « je ne sais pas » et « je préfère ne pas répondre » lorsque pertinent.

11.4 Sécurité du propre produit

ProofDesk doit pouvoir répondre à son propre questionnaire sécurité. Il faut préparer :

- page sécurité produit ;
- architecture ;
- liste des sous-traitants ;
- localisation des données ;
- sauvegardes ;
- gestion des accès ;
- incidents ;
- chiffrement ;
- gestion des vulnérabilités ;
- politique de conservation ;
- procédure de suppression.

Ne rien publier avant vérification réelle.

12. UX, design et accessibilité

12.1 Direction artistique

- B2B premium ;
- calme ;
- précis ;
- peu de couleurs ;
- contraste élevé ;
- hiérarchie éditoriale ;
- preuve visible ;
- pas d'effets « IA magique » ;
- pas de jargon inutile ;
- pas de surcharge de tableaux.

12.2 Principes d'interface

- l'état d'une question est toujours visible ;
- la source est accessible en un clic ;
- l'incertitude est expliquée ;
- les actions destructives nécessitent confirmation ;
- les actions longues affichent une progression ;
- les erreurs proposent une solution ;
- chaque page dispose d'une sortie claire ;
- les raccourcis clavier accélèrent la revue ;
- le mobile est prioritaire pour l'Audit, le desktop pour la revue SaaS.

12.3 Accessibilité

Objectif : WCAG 2.1 AA sur les parcours clés.

- navigation clavier ;

- focus visible ;
- labels accessibles ;
- contrastes conformes ;
- information non transmise par la couleur seule ;
- messages d'erreur associés aux champs ;
- lecteurs d'écran ;
- taille de clic suffisante ;
- préférence de réduction des animations ;
- PDF lisible et imprimable.

12.4 États à concevoir

Chaque module doit prévoir :

- chargement ;
 - état vide ;
 - premier usage ;
 - erreur ;
 - accès refusé ;
 - fichier invalide ;
 - traitement en cours ;
 - traitement bloqué ;
 - résultat partiel ;
 - succès ;
 - suppression ;
 - absence de preuve.
-

13. Analytics et pilotage

13.1 Événements Audit

- `landing_view` ;
- `audit_started` ;
- `audit_step_completed` ;
- `audit_abandoned` ;
- `audit_completed` ;
- `pdf_generated` ;
- `pdf_downloaded` ;
- `pdf_emailled` lorsque l'e-mail sera activé ;
- `cta_clicked` ;
- `account_created` ;
- `first_document_uploaded` ;
- `first_questionnaire_imported` ;
- `first_export` .

13.2 Événements SaaS

- `onboarding_started` ;
- `onboarding_completed` ;
- `document_uploaded` ;
- `document_validated` ;
- `questionnaire_import_started` ;
- `questionnaire_import_completed` ;
- `mapping_confirmed` ;
- `answer_generated` ;
- `answer_approved` ;
- `answer_edited` ;
- `answer_rejected` ;

- gap_detected ;
- export_created ;
- trust_center_previewed ;
- trust_center_published .

13.3 Minimisation

Ne pas stocker dans les événements :

- contenu de document ;
- réponses complètes ;
- clés API ;
- mots de passe ;
- données personnelles non nécessaires ;
- contenu de prompts complet si non indispensable.

14. Modèle économique à tester

Les prix sont des hypothèses commerciales, pas des décisions définitives.

Offre	Contenu	Hypothèse de prix
Audit	Audit express + rapport	Gratuit ou qualification payante à tester
Mise en place	Import initial, bibliothèque, premier questionnaire, restitution	1 500 à 3 000 €
SaaS initial	Organisation, utilisateurs limités, bibliothèque, questionnaires, revue, export	299 à 599 €/mois
SaaS avancé	Multi-produits, Trust Center avancé, intégrations, espaces privés, support prioritaire	800 à 1 500 €/mois

À valider avec les pilotes :

- prix lié au nombre d'utilisateurs ou de questionnaires ;
- paiement mensuel ou annuel ;
- coût de mise en place ;
- limite de traitement IA ;
- niveau de support ;
- facturation des intégrations ;
- engagement minimal.

Le prix premium doit être justifié par :

- le résultat livré ;
 - la qualité de l'export ;
 - l'accompagnement ;
 - la fiabilité ;
 - le support ;
 - la mesure de valeur.
-

15. Roadmap de construction

Phase 0 — Audit public et qualification

Objectif

Obtenir des leads qualifiés et démontrer la valeur avant le SaaS.

Livrables

- landing ;
- Audit express ;
- scoring déterministe ;
- rapport ;
- PDF ;

- consentement ;
- leads ;
- UTM ;
- analytics ;
- pages légales ;
- première transition vers création de compte.

Statut actuel

Le socle Audit, le PDF serveur, les leads enrichis et les événements analytics sont déjà amorcés dans le projet ProofDesk. Il reste à durcir les règles, la sécurité, la gestion de suppression et l'activation éventuelle d'un fournisseur e-mail.

Phase 1 — MVP SaaS questionnaire

Objectif

Un client réel traite un questionnaire de bout en bout.

Livrables

- organisations et rôles ;
- bibliothèque documentaire ;
- import PDF/DOCX/XLSX/TXT/MD ;
- extraction ;
- métadonnées ;
- import XLSX/DOCX/CSV ;
- mapping assisté ;
- création des questions ;
- propositions justifiées ;
- citations ;
- gap ;
- revue ;
- validation ;

- bibliothèque de réponses ;
- export fidèle ;
- journal d'audit ;
- dashboard de base.

Phase 2 — Fiabilité et Trust Center

- rappels d'expiration ;
- Gap Report ;
- commentaires et assignations ;
- modèles de réponses ;
- Trust Center FR/EN ;
- documents publics et contrôlés ;
- versions de publication ;
- domaine personnalisé ;
- page sécurité produit.

Phase 3 — Extension après validation

- import PDF questionnaire ;
- portails ;
- Google Drive ;
- SharePoint ;
- Notion ;
- Slack ;
- CRM ;
- espaces privés par prospect ;
- SSO ;
- multi-produits ;
- pays et langues supplémentaires.

Jalons business

Avant une extension importante :

1. contacter 20 à 30 PME ;
 2. réaliser 10 entretiens ;
 3. obtenir 5 questionnaires anonymisés ;
 4. lancer 3 pilotes payants ;
 5. mesurer le délai avant/après ;
 6. recueillir les objections ;
 7. confirmer le prix ;
 8. améliorer le moteur sur des cas réels.
-

16. Qualité et tests d'acceptation

16.1 Audit

- Audit terminé en moins de 8 minutes sur mobile et desktop ;
- progression sauvegardée ;
- aucune donnée sensible demandée ;
- consentement explicite et traçable ;
- score explicable ;
- PDF généré en moins de 30 secondes ;
- PDF FR/EN cohérent ;
- mentions et limites présentes ;
- aucun message de conformité automatique ;
- événements enregistrés ;
- suppression du lead possible.

16.2 SaaS

- utilisateur ne pouvant jamais lire une autre organisation ;
- rôle contrôlé côté serveur ;
- document importé et versionné ;
- preuve expirée toujours signalée ;
- contradiction toujours signalée ;
- chaque réponse proposée avec citation ou gap ;
- citation littérale retrouvable ;
- zéro hallucination critique dans le jeu d'évaluation ;
- export sans régression structurelle ;
- fichier exporté ouvrable dans les logiciels cibles ;
- questionnaire de 180 à 300 questions traité dans le délai cible à définir ;
- revue clavier-first ;
- journal d'audit complet ;
- interface FR/EN ;
- WCAG 2.1 AA sur les parcours clés ;
- export et suppression organisationnels ;
- sauvegarde et restauration testées ;
- client pilote capable de terminer sans aide technique.

16.3 Tests automatisés

- tests unitaires du scoring ;
- tests de validation de schéma ;
- tests des permissions ;
- tests d'isolation multi-tenant ;
- tests de génération de citations ;
- tests de preuve expirée ;
- tests de contradiction ;
- tests de parsing ;

- tests d'export ;
 - tests de non-régression structurelle ;
 - tests PDF ;
 - tests de rate limiting ;
 - tests d'injection de prompt ;
 - tests de suppression ;
 - tests de reprise de job.
-

17. Exploitation, support et qualité de service

17.1 Environnements

- développement ;
- staging ;
- production.

Chaque environnement doit disposer de :

- variables séparées ;
- base séparée ou données explicitement isolées ;
- stockage séparé ;
- logs séparés ;
- domaine de test ;
- procédure de rollback.

17.2 Observabilité

- logs JSON ;
- identifiant de requête ;
- identifiant d'organisation non sensible ;

- durée des jobs ;
- taux d'échec ;
- files en attente ;
- coût IA ;
- erreurs d'export ;
- erreurs d'authentification ;
- alertes de sécurité ;
- aucune réponse confidentielle dans les logs par défaut.

17.3 Support premium

- centre d'aide ;
- procédure de contact ;
- support français ;
- accompagnement d'onboarding ;
- session de démarrage ;
- canal pour les pilotes ;
- délai de réponse défini ;
- procédure d'incident communiquée.

17.4 Procédure incident

Documenter :

1. détection ;
2. qualification ;
3. confinement ;
4. correction ;
5. communication ;
6. notification si nécessaire ;
7. analyse de cause ;
8. action préventive ;

18. Décisions à prendre avant la construction complète

Les points suivants doivent être tranchés avant de figer l'architecture :

1. Audit gratuit ou payant ?
 2. E-mail automatique du PDF ou téléchargement uniquement au départ ?
 3. Fournisseur cloud et région exacte ;
 4. Fournisseur IA et politique de rétention ;
 5. Choix du moteur vectoriel ;
 6. Formats V1 confirmés : XLSX, DOCX, CSV ;
 7. Support ou refus des fichiers XLSM ;
 8. Seuils de confiance ;
 9. Délai cible pour 180 et 300 questions ;
 10. Prix et packaging ;
 11. Durée de conservation des leads et documents ;
 12. Niveau de Trust Center en V1.5 ;
 13. Domaine personnalisé ou non ;
 14. SSO en V2 ou avant les premiers grands comptes ;
 15. Intégration avec le setter ;
 16. Outil de rendez-vous ;
 17. Conseil juridique pour CGU, DPA et mentions ;
 18. Niveau de support humain inclus dans chaque offre ;
 19. Nombre de pilotes nécessaires avant extension ;
 20. Critères d'arrêt d'une fonctionnalité trop coûteuse.
-

19. Ordre de construction recommandé

Pour garder la cohérence, construire dans cet ordre :

1. verrouiller le modèle d'organisation et les rôles ;
2. mettre en place les permissions et l'audit log ;
3. fiabiliser le stockage et l'import documentaire ;
4. implémenter les versions et métadonnées ;
5. construire l'import questionnaire et le mapping ;
6. créer la vue question/réponse/source ;
7. ajouter la génération contrainte et les citations ;
8. ajouter la revue et l'approbation ;
9. construire l'export fidèle ;
10. ajouter la bibliothèque de réponses ;
11. ajouter les rappels ;
12. ajouter le dashboard ;
13. ajouter le Gap Report ;
14. ajouter le Trust Center ;
15. ajouter les intégrations uniquement après les pilotes.

Cette séquence évite de construire une belle interface autour d'un moteur documentaire ou d'un export encore peu fiable.

20. Résultat attendu du vrai MVP

Le MVP est considéré comme utile lorsqu'une PME SaaS peut :

1. créer son organisation ;
2. inviter trois utilisateurs ;
3. importer ses documents de sécurité ;
4. renseigner les propriétaires et expirations ;
5. importer un questionnaire Excel, Word ou CSV ;

6. confirmer le mapping ;
7. obtenir des propositions de réponses ;
8. voir les citations et les lacunes ;
9. assigner les questions ;
10. faire valider les réponses ;
11. générer un export fidèle ;
12. retrouver les réponses approuvées au questionnaire suivant ;
13. consulter un dashboard de progression ;
14. exporter ou supprimer ses données ;
15. expliquer à un grand compte d'où vient chaque réponse.

Définition finale de la valeur

ProofDesk n'est pas un générateur de texte. C'est un système de préparation, de preuve, de validation et de capitalisation des réponses sécurité qui aide une entreprise à avancer plus vite dans ses ventes sans perdre le contrôle de ses affirmations.

Annexe A — Terminologie officielle

Terme	Définition
Preuve	Document ou extrait vérifiable qui soutient une affirmation
Citation	Extrait littéral associé à une réponse
Gap	Information ou preuve insuffisante pour répondre de façon fiable
Réponse approuvée	Réponse validée par un utilisateur autorisé
Questionnaire	Fichier ou demande contenant les questions d'un prospect
Trust Center	Page de présentation contrôlée de la posture sécurité d'une organisation
Réponse expirée	Réponse dont une preuve liée n'est plus valide
Contradiction	Deux sources qui soutiennent des affirmations incompatibles
Mapping	Association entre les zones du fichier et les champs ProofDesk
Export fidèle	Fichier final conservant la structure originale hors zones de réponse

Annexe B — Messages produit recommandés

- « Préparez plus vite. Validez toujours. »
- « Une réponse sans preuve est une réponse à revoir. »
- « Nous avons trouvé une lacune, pas une réponse fiable. »
- « Cette preuve doit être vérifiée avant export. »
- « Votre équipe garde la validation finale. »
- « ProofDesk ne certifie pas votre conformité ; il vous aide à préparer des réponses documentées. »

Annexe C — Messages à éviter

- « Notre IA répond à tout. »
- « Conforme automatiquement à NIS2. »
- « Zéro effort. »
- « Gain garanti de X heures. »
- « Réponse sûre à 100 %. »
- « Remplace votre RSSI ou votre DPO. »
- « La conformité en un clic. »

Fin du cahier des charges.